Test d’intrusion par ingénierie sociale

Compromission d’un poste via un document Excel macro-piégé — « Entreprise Fictive »

Octobre 2026

EFREI — ST2EH : Ethical Hacking
Enseignant : Souheib Yousfi

Contexte & objectif

- Projet : simuler une attaque réaliste pour **identifier et exploiter** les vulnérabilités.
- Entreprise Fictive : site e-commerce, serveurs web, base clients sensible.
- **Choix** : viser le maillon le plus faible — l'humain — plutôt que les serveurs.
- Scénario : un collaborateur du service financier piégé par un e-mail et un fichier Excel.

Pourquoi l'ingénierie sociale ?

On ne pirate pas un pare-feu, on pirate une **habitude**. Un contrôleur de gestion ouvre des `.xlsm` toute la journée.

Méthodologie & environnement

- Les **5 phases** classiques de l'ethical hacking.
- Chaque phase reliée à la **Cyber Kill Chain** et à **MITRE ATT&CK**.

Rôle	Système	Adresse IP
Attaquant	Kali Linux	*192.168.1.65*
Cible	Windows 10 x64	*192.168.1.57*
Messagerie	PaperCut SMTP	(laboratoire)

Reconnaissance → Scanning & Énumération → Gaining Access → Maintaining Access → Covering Tracks

La chaîne d'attaque, d'un coup d'œil

1. **OSINT** — identifier la cible et la Directrice Financière à usurper.
2. **Piège** — Excel « chiffré » + macro + reverse shell.
3. **Phishing** — e-mail usurpé urgent, fichier en archive RAR.
4. **Contrôle** — activation des macros → session, droits admin, persistance.
5. **Effacement** — horodatages falsifiés + journaux effacés.

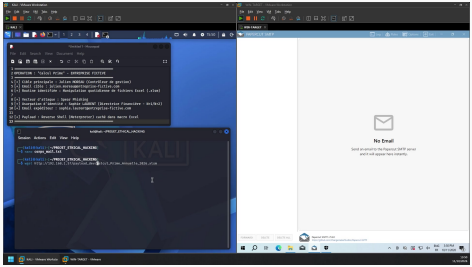
Message clé

Compromission totale **sans aucune faille logicielle** : seulement de l'OSINT, un prétexte crédible et des faiblesses de configuration.

Phase 1 — Reconnaissance (OSINT)

Reconnaissance (OSINT)

- Google Dork LinkedIn → **Julien Moreau**, contrôleur de gestion (cible).
- Hiérarchie → **Sophie Laurent**, Directrice Financière (identité usurpée).
- Domaine via le site vitrine ; format d'e-mail déduit avec **Skrapp**.
- *prenom.nom@entreprise-fictive.com*
- V1 — surface OSINT : employés, hiérarchie et format d'e-mail déductibles.



Plan de l'opération + boîte en attente

Phase 2 — Scanning & Énumération

Scanning & Énumération

- Scénario « côté client » : la compromission passe par une action de l'utilisateur.
- Le scan réseau (nmap) est secondaire ; on qualifie trois surfaces :
  - **Humaine** : cible + hiérarchie + routine métier (*`.xlsm`* quotidiens).
  - **Messagerie** : relais SMTP interne atteignable, sans authentification.
  - **Logicielle** : Office avec macros VBA, WinRAR présent.
- V2 — relais SMTP acceptant une adresse interne usurpée (ni SPF/DKIM/DMARC).

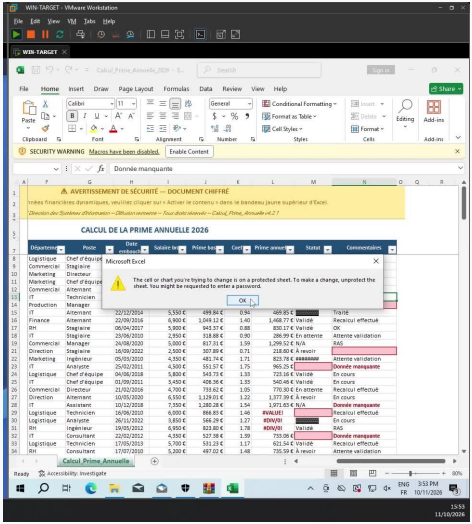
Phase 3 — Gaining Access

Weaponization — le leurre « document chiffré »

- On fabrique un classeur RH réaliste, enregistré en .xlsm, le format qui autorise les macros. Le piège repose sur une mise en scène : un faux bandeau « document chiffré » et une feuille protégée qui bloque toute modification.
- **Résultat :** l'utilisateur est canalisé vers un seul geste — « Activer le contenu ».

C'est le cœur du projet

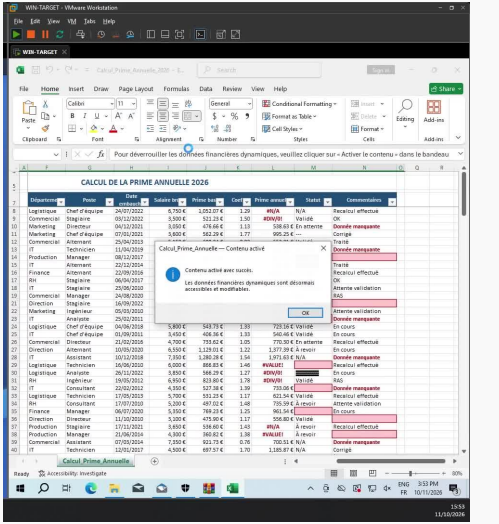
Le « chiffrement » est une mise en scène qui **force** l'activation des macros.



Bandeau + pop-up « feuille protégée »

La macro — camouflage + charge

- À l'activation, une macro ***Workbook_Open*** s'exécute automatiquement.
- Elle a deux fonctions :
- **1 - Camouflage** : retire la protection, masque le bandeau et affiche « Contenu activé », ce qui donne une impression de déchiffrement.
- La victime croit simplement avoir « déchiffré » le fichier.
- **2 - Exécution de la charge** : en toute discrétion, la charge (msfvenom) s'exécute.
- Shellcode Meterpreter lancé **en mémoire** dans Excel (*fileless*).



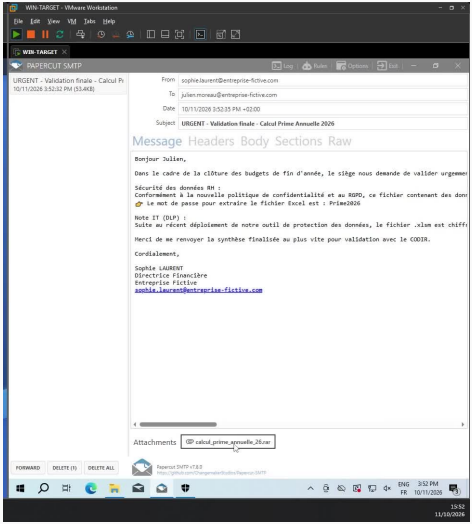
« Contenu activé » — bandeau disparu

Delivery — le courriel de spear-phishing

- Envoi via **swaks** en usurpant l'adresse de la Directrice Financière.
- Fichier livré en **archive RAR chiffrée** → échappe à l'antivirus du mail.

Leviers d'influence :

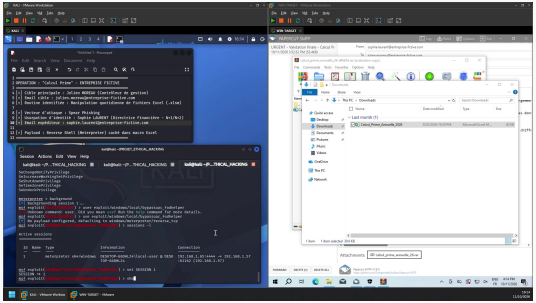
- **Autorité** — signé « Directrice Financière ».
- **Urgence** — « avant 15h aujourd'hui ».
- **Prétexte DLP / caution RGPD** — justifie l'archive protégée.



Courriel reçu + pièce jointe RAR

Exploitation — session obtenue

- Côté Kali : un *multi/handler* attend la connexion.
- Côté victime : extraction (*Prime2026*) → « Activer le contenu ».
- **Le reverse shell se connecte : session Meterpreter.**
- Contexte : *DESKTOP-66DHL24\local-user*.
- V3–V5 — macros autorisées, archive non filtrée, utilisateur non sensibilisé.

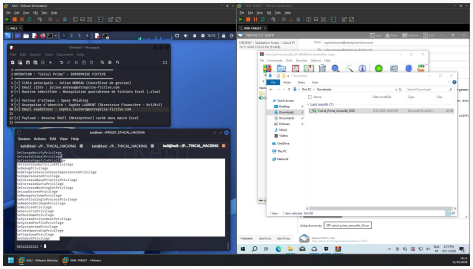


Session Meterpreter depuis 192.168.1.57

Phase 4 — Maintaining Access

Maintaining Access

- Élévation : contournement de l'UAC via le module **fodhelper**.
- → **intégrité élevée : privilèges d'administrateur** (compte ***local-user***).
- Migration : le Meterpreter passe dans un processus stable.
- Persistance : binaire déposé + clé de registre ***Run*** « WindowsUpdate ».
- V6–V8 — admin local + UAC contournable, pas d'EDR, persistance non supervisée.

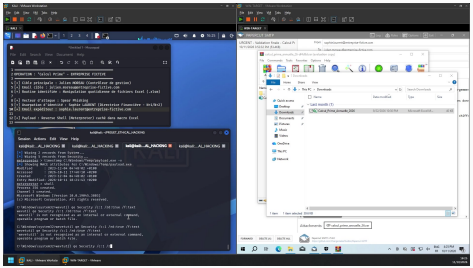


Privilèges élevés (***getprivs***)

Phase 5 — Covering Tracks

Covering Tracks

- **Timestomp** : falsification des horodatages (MACE) du binaire.
- **Clearev** : effacement des journaux Windows (System, Security).
- Objectif : entraver la détection et l'analyse forensique.
- Limite : clearev génère l'événement 1102 — une alerte en soi !
- V9 — journaux non centralisés (pas de SIEM/WEF).



Effacement des journaux + timestomp

Démonstration en direct

Bilan & défense

Synthèse des 9 vulnérabilités

ID	Vulnérabilité	Criticité
V1	Exposition OSINT (employés, format e-mail)	Moyenne
V2	Messagerie sans anti-usurpation (SPF/DKIM/DMARC)	Élevée
V3	Macros Office exécutables sans restriction	Élevée
V4	Archives chiffrées non filtrées	Moyenne
V5	Absence de sensibilisation des utilisateurs	Élevée
V6	Admin local + UAC contournable	Élevée
V7	Absence d'antivirus / EDR actif	Critique
V8	Persistance (Run, Temp) non supervisée	Élevée
V9	Journaux non centralisés (SIEM/WEF)	Élevée

Recommandations — défense en profondeur

Messagerie

SPF/DKIM/DMARC en rejet ; relais authentifié ; filtrer les archives chiffrées.

Détection

Journaux centralisés (SIEM, Sysmon, WEF) ; alerte sur l'événement 1102 ; FIM.

Poste de travail

Bloquer les macros Internet ; règles ASR ; retirer l'admin local ; EDR + anti-sabotage.

Facteur humain

Sensibilisation + phishing simulé ; vérification hors-canal des demandes urgentes.

Responsabilité & conclusion

- Cadre : mission autorisée, laboratoire isolé, cibles fictives.
- **Mêmes techniques qu'une attaque réelle — seuls l'intention et le mandat changent.**
- Diffusion responsable : on documente la méthode, pas de quoi la reproduire clé en main.

À retenir

Un simple clic sur « Activer le contenu » a suffi à compromettre le poste, l'élever en **administrateur**, le rendre persistant et effacer les traces — **sans aucune faille logicielle**.

Merci de votre attention

Questions & échanges